

CONFIDENTIEL — RAPPORT DE DURCISSEMENT SSH

G. TCHIBANVUNYA | PURPLE TEAM OPS

# Rapport d'évaluation et de durcissement SSH

Client fictif : MicroLogistics SARL

Date : 22/10/2026, 15:07 – 15:55

Auteur : Gédéon Tchibanvunya — Purple Team

Environnement : Lab isolé (réseau host-only, aucune machine réelle de production)

Document confidentiel — usage interne uniquement

## 1. Objectif de la mission

Démontrer le risque d'un service SSH mal configuré (brute force possible), puis fournir la remédiation concrète (durcissement), et prouver son efficacité par un nouveau test.

## 2. Topologie du lab

| Machine | IP | Rôle |
|---|---|---|
| Kali Linux | 10.0.2.10 | Attaquant |
| Ubuntu | 10.0.2.9 | Serveur victime (SSH) |

## 3. Qu'est-ce que SSH ?

SSH (Secure Shell) est un protocole utilisé en entreprise pour accéder à des machines distantes de manière sécurisée. Il a été créé pour éviter les vulnérabilités liées à Telnet, qui transmet les données sans chiffrement.

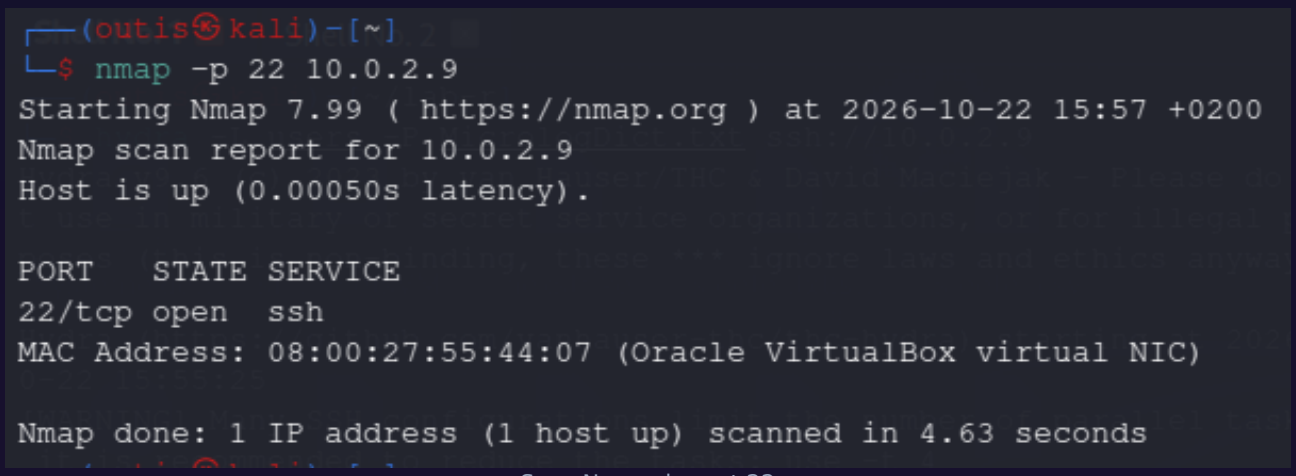
## 4. Outils utilisés

- Nmap — énumération du port SSH
- Hydra — brute force
- Fail2ban — surveillance et blocage des anomalies
- OpenSSH — service SSH du serveur

## 5. Déroulé de l'attaque

### 5.1 Reconnaissance réseau

La première étape a été de vérifier si le service SSH était disponible sur le port 22, ce qui a été confirmé, comme le montre la capture ci-dessous.



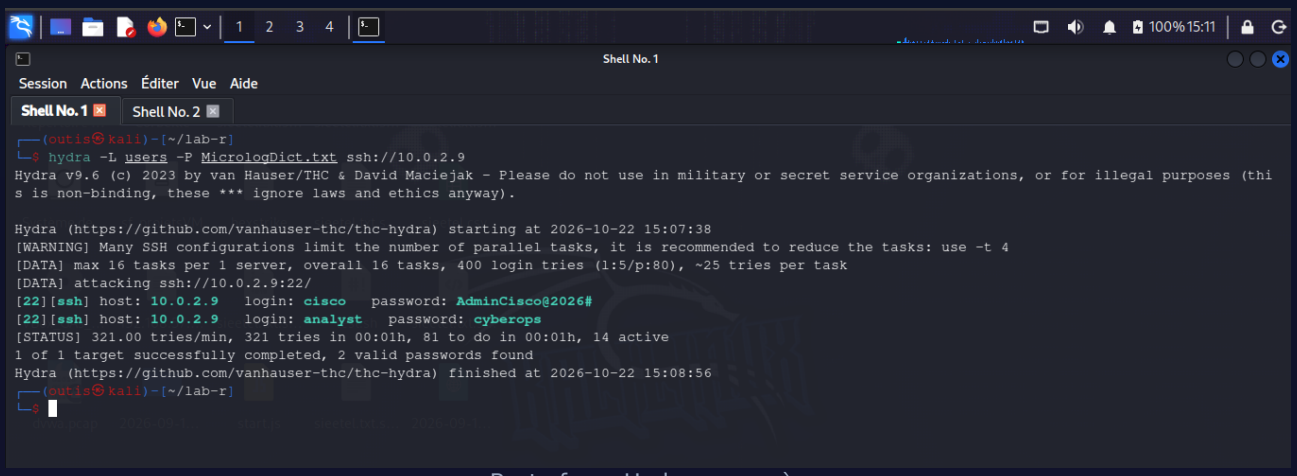

Scan Nmap du port 22

### 5.2 Test de brute force

Hydra a été chargé avec deux dictionnaires :

- `users` : liste de noms d'utilisateur possibles
- `MicrologDict.txt` : dictionnaire de mots de passe à tester

Résultat : deux utilisateurs (`cisco` et `analyst`) ont été compromis avec des mots de passe présents dans le dictionnaire, comme le montre la capture ci-dessous.




Brute force Hydra — succès

Les noms d'utilisateur ont été sélectionnés à partir d'une phase d'énumération par timing des réponses SSH (technique basée sur les différences de temps de réponse entre utilisateurs valides et invalides). Les tests se sont révélés inconcluants : OpenSSH est patché et ne divulgue plus cette information, ce qui a conduit à un choix basé sur des conventions courantes (comptes de service/administration).

## 5.3 Côté serveur

Surveillance des logs avec `tail -f /var/log/auth.log`, qui montre plusieurs tentatives de mot de passe en quelques millisecondes — comportement typique d'un brute force, comme le montrent les captures ci-dessous.

```
File  Edit  View  Search  Terminal  Help
Oct 22 13:07:39 labvm sshd[3169]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=cisco
Oct 22 13:07:39 labvm sshd[3170]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=cisco
Oct 22 13:07:39 labvm sshd[3179]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=cisco
Oct 22 13:07:39 labvm sshd[3177]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=cisco
Oct 22 13:07:39 labvm sshd[3171]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=cisco
Oct 22 13:07:39 labvm sshd[3174]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=cisco
Oct 22 13:07:39 labvm sshd[3173]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=cisco
Oct 22 13:07:39 labvm sshd[3176]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=cisco
Oct 22 13:07:39 labvm sshd[3178]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=cisco
Oct 22 13:07:39 labvm sshd[3175]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=cisco
Oct 22 13:07:39 labvm sshd[3180]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=cisco
Oct 22 13:07:39 labvm sshd[3181]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=cisco
Oct 22 13:07:39 labvm sshd[3182]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=cisco
Oct 22 13:07:39 labvm sshd[3172]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=cisco
Oct 22 13:07:41 labvm sshd[3169]: Failed password for cisco from 10.0.2.10 port 57730 ssh2
Oct 22 13:07:41 labvm sshd[3179]: Failed password for cisco from 10.0.2.10 port 57850 ssh2
Oct 22 13:07:41 labvm sshd[3170]: Failed password for cisco from 10.0.2.10 port 57732 ssh2
Oct 22 13:07:41 labvm sshd[3177]: Failed password for cisco from 10.0.2.10 port 57804 ssh2
Oct 22 13:07:41 labvm sshd[3174]: Failed password for cisco from 10.0.2.10 port 57776 ssh2
Oct 22 13:07:41 labvm sshd[3171]: Failed password for cisco from 10.0.2.10 port 57748 ssh2
Oct 22 13:07:41 labvm sshd[3173]: Failed password for cisco from 10.0.2.10 port 57762 ssh2
Oct 22 13:07:41 labvm sshd[3176]: Failed password for cisco from 10.0.2.10 port 57798 ssh2
Oct 22 13:07:41 labvm sshd[3178]: Failed password for cisco from 10.0.2.10 port 57818 ssh2
Oct 22 13:07:41 labvm sshd[3175]: Failed password for cisco from 10.0.2.10 port 57788 ssh2
Oct 22 13:07:41 labvm sshd[3180]: Failed password for cisco from 10.0.2.10 port 57860 ssh2
Oct 22 13:07:41 labvm sshd[3181]: Failed password for cisco from 10.0.2.10 port 57874 ssh2
Oct 22 13:07:41 labvm sshd[3182]: Failed password for cisco from 10.0.2.10 port 57882 ssh2
Oct 22 13:07:41 labvm sshd[3172]: Failed password for cisco from 10.0.2.10 port 57756 ssh2
Oct 22 13:07:45 labvm sshd[3169]: Failed password for cisco from 10.0.2.10 port 57730 ssh2
Oct 22 13:07:45 labvm sshd[3170]: Failed password for cisco from 10.0.2.10 port 57732 ssh2
Oct 22 13:07:45 labvm sshd[3171]: Failed password for cisco from 10.0.2.10 port 57748 ssh2
Oct 22 13:07:45 labvm sshd[3179]: Failed password for cisco from 10.0.2.10 port 57850 ssh2
Oct 22 13:07:45 labvm sshd[3177]: Failed password for cisco from 10.0.2.10 port 57804 ssh2
```

Logs — échecs cisco

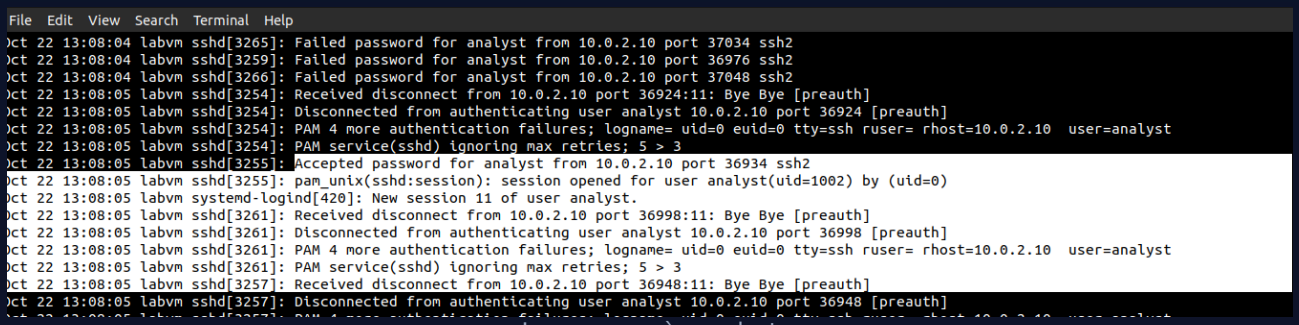
```
File  Edit  View  Search  Terminal  Help
Oct 22 13:07:50 labvm sshd[3266]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=analyst
Oct 22 13:07:51 labvm sshd[3198]: Failed password for analyst from 10.0.2.10 port 57908 ssh2
Oct 22 13:07:51 labvm sshd[3202]: Failed password for analyst from 10.0.2.10 port 57934 ssh2
Oct 22 13:07:51 labvm sshd[3197]: Failed password for analyst from 10.0.2.10 port 57898 ssh2
Oct 22 13:07:51 labvm sshd[3200]: Failed password for analyst from 10.0.2.10 port 57922 ssh2
Oct 22 13:07:52 labvm sshd[3253]: Failed password for analyst from 10.0.2.10 port 36900 ssh2
Oct 22 13:07:52 labvm sshd[3254]: Failed password for analyst from 10.0.2.10 port 36924 ssh2
Oct 22 13:07:52 labvm sshd[3255]: Failed password for analyst from 10.0.2.10 port 36934 ssh2
Oct 22 13:07:52 labvm sshd[3261]: Failed password for analyst from 10.0.2.10 port 36998 ssh2
Oct 22 13:07:52 labvm sshd[3262]: Failed password for analyst from 10.0.2.10 port 37024 ssh2
Oct 22 13:07:52 labvm sshd[3257]: Failed password for analyst from 10.0.2.10 port 36948 ssh2
Oct 22 13:07:52 labvm sshd[3260]: Failed password for analyst from 10.0.2.10 port 36986 ssh2
Oct 22 13:07:52 labvm sshd[3259]: Failed password for analyst from 10.0.2.10 port 36976 ssh2
Oct 22 13:07:52 labvm sshd[3265]: Failed password for analyst from 10.0.2.10 port 37034 ssh2
Oct 22 13:07:52 labvm sshd[3266]: Failed password for analyst from 10.0.2.10 port 37048 ssh2
Oct 22 13:07:55 labvm sshd[3198]: Failed password for analyst from 10.0.2.10 port 57908 ssh2
Oct 22 13:07:55 labvm sshd[3202]: Failed password for analyst from 10.0.2.10 port 57934 ssh2
Oct 22 13:07:55 labvm sshd[3197]: Failed password for analyst from 10.0.2.10 port 57898 ssh2
Oct 22 13:07:55 labvm sshd[3200]: Failed password for analyst from 10.0.2.10 port 57922 ssh2
Oct 22 13:07:55 labvm sshd[3253]: Failed password for analyst from 10.0.2.10 port 36900 ssh2
Oct 22 13:07:55 labvm sshd[3255]: Failed password for analyst from 10.0.2.10 port 36934 ssh2
Oct 22 13:07:55 labvm sshd[3254]: Failed password for analyst from 10.0.2.10 port 36924 ssh2
Oct 22 13:07:55 labvm sshd[3261]: Failed password for analyst from 10.0.2.10 port 36998 ssh2
Oct 22 13:07:55 labvm sshd[3257]: Failed password for analyst from 10.0.2.10 port 36948 ssh2
Oct 22 13:07:55 labvm sshd[3262]: Failed password for analyst from 10.0.2.10 port 37024 ssh2
Oct 22 13:07:55 labvm sshd[3260]: Failed password for analyst from 10.0.2.10 port 36986 ssh2
Oct 22 13:07:55 labvm sshd[3265]: Failed password for analyst from 10.0.2.10 port 37034 ssh2
Oct 22 13:07:55 labvm sshd[3259]: Failed password for analyst from 10.0.2.10 port 36976 ssh2
Oct 22 13:07:55 labvm sshd[3266]: Failed password for analyst from 10.0.2.10 port 37048 ssh2
Oct 22 13:07:57 labvm sshd[3198]: Failed password for analyst from 10.0.2.10 port 57908 ssh2
Oct 22 13:07:57 labvm sshd[3202]: Failed password for analyst from 10.0.2.10 port 57934 ssh2
Oct 22 13:07:58 labvm sshd[3197]: Failed password for analyst from 10.0.2.10 port 57898 ssh2
Oct 22 13:07:58 labvm sshd[3200]: Failed password for analyst from 10.0.2.10 port 57922 ssh2
```

Logs — échecs analyst

Puis les connexions réussies pour les deux comptes compromis :

```
Oct 22 13:07:45 labvm sshd[3174]: Failed password for cisco from 10.0.2.10 port 57776 ssh2
Oct 22 13:07:45 labvm sshd[3173]: Failed password for cisco from 10.0.2.10 port 57762 ssh2
Oct 22 13:07:45 labvm sshd[3176]: Failed password for cisco from 10.0.2.10 port 57798 ssh2
Oct 22 13:07:45 labvm sshd[3175]: Failed password for cisco from 10.0.2.10 port 57788 ssh2
Oct 22 13:07:45 labvm sshd[3178]: Failed password for cisco from 10.0.2.10 port 57818 ssh2
Oct 22 13:07:45 labvm sshd[3180]: Failed password for cisco from 10.0.2.10 port 57860 ssh2
Oct 22 13:07:45 labvm sshd[3181]: Failed password for cisco from 10.0.2.10 port 57874 ssh2
Oct 22 13:07:45 labvm sshd[3182]: Failed password for cisco from 10.0.2.10 port 57882 ssh2
Oct 22 13:07:45 labvm sshd[3172]: Failed password for cisco from 10.0.2.10 port 57756 ssh2
Oct 22 13:07:46 labvm sshd[3180]: Accepted password for cisco from 10.0.2.10 port 57860 ssh2
Oct 22 13:07:46 labvm sshd[3180]: pam_unix(sshd:session): session opened for user cisco(uid=1001) by (uid=0)
Oct 22 13:07:46 labvm systemd-logind[420]: New session 10 of user cisco.
Oct 22 13:07:46 labvm sshd[3181]: Received disconnect from 10.0.2.10 port 57874:11: Bye Bye [preauth]
Oct 22 13:07:46 labvm sshd[3181]: Disconnected from authenticating user cisco 10.0.2.10 port 57874 [preauth]
Oct 22 13:07:46 labvm sshd[3181]: PAM 1 more authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=10.0.2.10  user=cisco
Oct 22 13:07:46 labvm sshd[3182]: Received disconnect from 10.0.2.10 port 57882:11: Bye Bye [preauth]
```

Logs — succès cisco

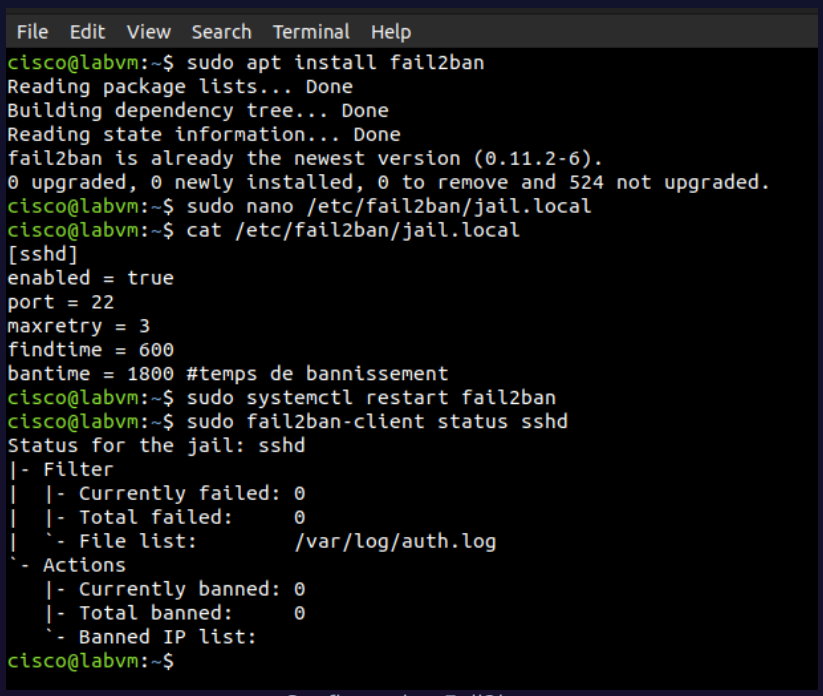



Logs — succès analyst

## 5.4 Première mesure : Fail2ban

Fail2ban a été installé pour surveiller le fichier de log et bannir tout comportement anormal provenant d'une IP. La configuration a été réalisée dans `jail.local` avec les valeurs suivantes :

- `maxretry = 3` (nombre d'échecs avant bannissement)
- `findtime = 600s` (fenêtre de détection)
- `bantime = 1800s` (durée du bannissement)




Configuration Fail2ban

Après configuration et lancement de Fail2ban, l'IP de l'attaquant a été bannie :

```
cisco@labvm:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
|  |- Currently failed: 0
|  |- Total failed:     0
|  `- File list:        /var/log/auth.log
`- Actions
   |- Currently banned: 0
   |- Total banned:     0
   `- Banned IP list:
cisco@labvm:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
|  |- Currently failed: 1
|  |- Total failed:     28
|  `- File list:        /var/log/auth.log
`- Actions
   |- Currently banned: 1
   |- Total banned:     1
   `- Banned IP list:   10.0.2.10
cisco@labvm:~$
```

IP bannie par Fail2ban

## 5.5 Nouvelle tentative depuis Kali

Une fois Fail2ban configuré, l'attaque a été relancée pour observer la réaction. Kali a été banni après quelques tentatives, ce qui a provoqué l'échec de l'attaque Hydra.

```
┌──(outis㉿kali)-[~/lab-r]
└─$ hydra -L users -P MicrologDict.txt ssh://10.0.2.9
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (thi
s is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-22 15:32:05
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 400 login tries (l:5/p:80), ~25 tries per task
[DATA] attacking ssh://10.0.2.9:22/
[STATUS] 58.00 tries/min, 58 tries in 00:01h, 344 to do in 00:06h, 14 active
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-22 15:34:10
┌──(outis㉿kali)-[~/lab-r]
└─$ ip a show eth2
4: eth2: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2c:10:e7 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.10/24 brd 10.0.2.255 scope global dynamic noprefixroute eth2
       valid_lft 355sec preferred_lft 355sec
    inet6 fe80::47d8:323f:40fe:6829/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
┌──(outis㉿kali)-[~/lab-r]
└─$
```

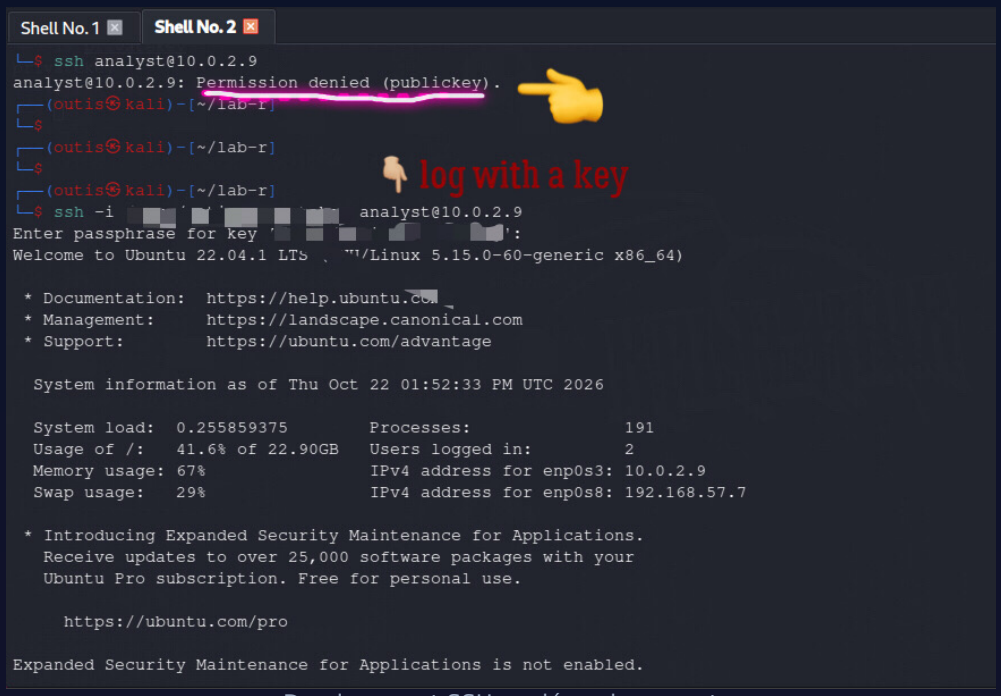
Hydra — échec après bannissement

Pour débannir manuellement une IP :

```
fail2ban-client set sshd unbanip <IP>
```

## 5.6 Durcissement du serveur

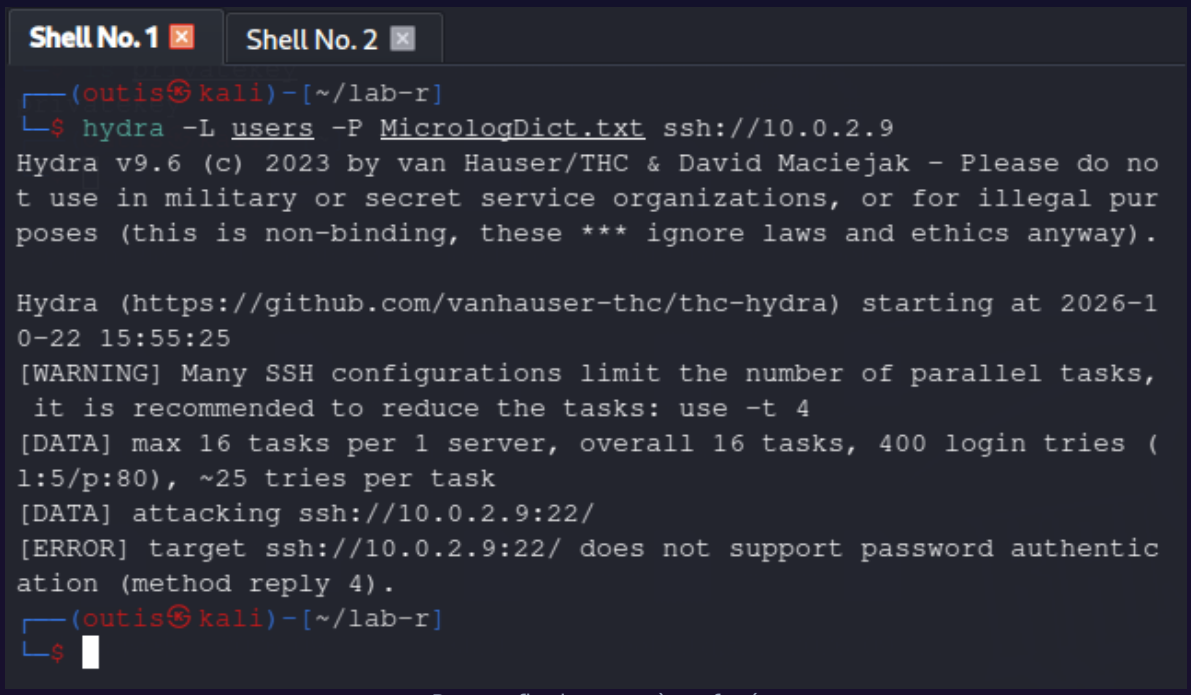
Fail2ban permet de bannir une tentative répétée de mot de passe dans un délai déterminé, mais n'empêche pas un attaquant de se connecter avec un mot de passe obtenu lors de l'attaque. Le serveur a donc été durci : authentification par clé uniquement, mot de passe désactivé.




Durcissement SSH — clés uniquement

## 5.7 Test avec la configuration serveur

L'attaquant a relancé l'attaque par brute force après le durcissement du serveur. L'authentification par mot de passe étant désormais désactivée, cette nouvelle tentative a échoué : seule une authentification par clé SSH est autorisée.




Preuve finale — accès refusé

## 6. Résultats

| Cause | Conséquence |
|---|---|
| Serveur mal configuré | Brute force réussi |
| Durcissement serveur + Fail2ban | Hydra impuissant |

## 7. Recommandations

• Le protocole SSH est sécurisé en soi, mais seule la configuration derrière le serveur le rend plus robuste.

• Désactiver l'authentification par mot de passe au profit de l'authentification par clé.

• Utiliser Fail2ban pour bannir automatiquement toute tentative de brute force.

• Surveiller régulièrement les logs d'authentification (`/var/log/auth.log`).

## 8. Synthèse (5 Ws)

| | |
|---|---|
| Who | 10.0.2.10 (Kali — attaquant) |
| What | Attaque par brute force SSH, puis durcissement et validation |
| When | 15:07 – 15:55, 22/10/2026 |
| Where | Réseau interne MicroLogistics SARL (10.0.2.0/24) |
| Why | Test de pénétration autorisé, démontrer le risque d'un SSH mal configuré |

---

Ce test a été réalisé dans un environnement isolé, à but strictement éducatif et dans le cadre d'un mandat autorisé. Les techniques démontrées peuvent causer un préjudice réel si utilisées sans autorisation. L'auteur décline toute responsabilité en cas d'usage malveillant de ces informations.

Gédéon Tchibanvunya — Purple Team